Activité 1 – attaque MITM d'un service SSH et mise en place de contre-mesures

Partie 1 – Attaque MITM d'un service SSH

Q1. Pourquoi l'accès aux machines virtuelles par la console ou l'interface graphique n'est pas possible avec le super-administrateur root ?

Car de base dans le fichier de configuration l'accès en super-administrateur n'est pas autorisé et donc il faut rajouter la ligne **PermitRootLogin yes**

Q2. Expliquer à quoi sert la commande sudo et quels avantages a-t-elle sur l'utilisation de la commande su - ?

La commande **sudo** permet d'élever les droits sur une commande seulement. **su** permet de se mettre sur un cli en "root" et donc plus dangereux que d'être en user et de juste mettre **sudo** devant une commande

Q3. Quelles commandes permettent de savoir si le service OpenSSH (serveur) est déjà installé et démarré ?

La commande **systemctl status ssh** permet de voir l'état de OpenSSH,

```
etusio@srvssh:~$ systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enab
   Active: active (running) since Tue 2025-11-25 08:40:55 CET; 47min ago
     Docs: man:sshd(8)
           man:sshd_config(5)
  Process: 425 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
 Main PID: 454 (sshd)
```

Q4. Indiquer le répertoire où sont stockées les clés publique et privée créées ainsi que le positionnement des permissions appliquées sur les fichiers correspondants. Puis indiquer quel est le fichier de configuration du service SSH.

Le répertoire où sont stockés les clés publique et privée sont dans /etc/ssh/

Grâce à **ls -l** on peut voir les permissions sur les différents fichiers du répertoire, le fichier de configuration se trouve dans **sshd_config**

```
etusio@srvssh:/etc/ssh$ ls -l /etc/ssh/
total 584
-rw-r--r-- 1 root root 565189 janv. 31  2020 moduli
-rw-r--r-- 1 root root   1580 janv. 31  2020 ssh_config
-rw-r--r-- 1 root root   3250 janv. 31  2020 sshd_config
-rw------- 1 root root    505 mars  29  2020 ssh_host_ecdsa_key
-rw-r--r-- 1 root root    173 mars  29  2020 ssh_host_ecdsa_key.pub
-rw------- 1 root root    399 mars  29  2020 ssh_host_ed25519_key
-rw-r--r-- 1 root root     93 mars  29  2020 ssh_host_ed25519_key.pub
-rw------- 1 root root   1823 mars  29  2020 ssh_host_rsa_key
-rw-r--r-- 1 root root    393 mars  29  2020 ssh_host_rsa_key.pub
```

Première utilisation

Utilisation des annexes 1 à 5

Q5. Que signifie cette alerte qui est affichée à l'écran ? Devez-vous continuer l'opération ? Pourquoi ?

Cette alerte signifie que l'authenticité de l'hôte "srvssh.local.sio.fr" ne peut pas être établie car il ne le connaît pas en tant qu'hôte. Oui on peut continuer l'opération car il va l'ajouter dans les hôtes connus

```
Warning: Permanently added 'srvssh.local.sio.fr' (ECDSA) to the list of known hosts.
```

Q6. Lors d'une prochaine connexion depuis le même client sur ce serveur, ce message apparaîtra-t-il à nouveau ? Pourquoi ?

Non il n'apparaît pas de nouveau car il est déjà connu donc il ne demande pas de permission, par contre il nous demande le mot de passe pour se connecter en SSH.

```
etusio@clissh:~$ ssh etusio@srvssh.local.sio.fr
etusio@srvssh.local.sio.fr's password:
```

Q7. Sur la machine virtuelle cliente, expliquer à quoi sert le fichier /home/etusio/.ssh/known_hosts.

Le fichier **known_hosts** permet de savoir qu'elle hôte SSH la machine connaît donc par exemple lui "srvssh.local.sio.fr" car il l'a ajouté tout à l'heure lors de la première connexion.

À ce stade du TP, supprimer le **contenu** du fichier known_hosts (attention, ne pas supprimer le fichier).

```
etusio@clissh:~/.ssh$ cat known_hosts
|1|2oN8XpD3DVmrioTHQkNLRQBQmQU=|LgxHnqmsGwlY3CXYCgz/y6GV
bmlzdHAyNTYAAABBBKBIccKG7qS9Tmm7DkTS1/HU2k7qtgloRAg+fb4e
|1|kBZxpC44dHNqgPpEgmpATi7iY2w=|6qoj3dMMi6QaR+W2HYNhAFBk
bmlzdHAyNTYAAABBBKBIccKG7qS9Tmm7DkTS1/HU2k7qtgloRAg+fb4e
etusio@clissh:~/.ssh$
etusio@clissh:~/.ssh$
etusio@clissh:~/.ssh$ echo > ~/.ssh/known_hosts
etusio@clissh:~/.ssh$ cat known_hosts

etusio@clissh:~/.ssh$
```

On peut voir que le contenu a bien été supprimé

Découverte des hôtes et services présents sur un réseau local

Q8. Indiquer quelles sont les informations que peut obtenir un attaquant grâce à ces commandes ?

La commande nmap -sP permet de savoir qu'elle machine sont en ligne sur le réseau "192.168.56.0"

```
etusio@kali:~$ nmap -sP 192.168.56.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2025-11-25 09:55 CET
Nmap scan report for 192.168.56.1
Host is up (0.00067s latency).
Nmap scan report for srvssh.local.sio.fr (192.168.56.10)
Host is up (0.00052s latency).
Nmap scan report for clissh.local.sio.fr (192.168.56.11)
Host is up (0.00082s latency).
Nmap scan report for kali.local.sio.fr (192.168.56.12)
Host is up (0.00079s latency).
Nmap scan report for rwbsd.local.sio.fr (192.168.56.254)
Host is up (0.0019s latency).
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.65 seconds
```

La commande nmap -sV "192.168.56.10" permet de savoir le service en écoute et sa version

```
PORT    STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
53/tcp open  domain  ISC BIND 9.11.5-P4-5.1+deb10u2 (Debian Linux)
```

Simulation d’une attaque de l’homme du milieu entre votre client et votre serveur SSH

Q9. Expliquer les principes généraux d’une attaque de l’homme du milieu (Man in the Middle).

MITM est une attaque qui a pour but d'intercepter les communications entre deux parties, sans que ni l'une ni l'autre ne puisse se douter que le canal de communication entre elles a été compromis.

L'attaque « homme du milieu » est particulièrement applicable dans la méthode d'échange de clés Diffie-Hellman.

Dans l'attaque de l'homme du milieu, l'attaquant a non seulement la possibilité de lire, mais aussi de modifier les messages.

Dans un premier temps, sur le client et le serveur SSH, analyser le cache ARP respectif des deux machines à l’aide de la commande

Sur le serveur SSH :

```
etusio@srvssh:~$ ip neigh show
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:06 REACHABLE
192.168.56.12 dev enp0s3 lladdr 08:00:27:32:9e:4e STALE
192.168.56.11 dev enp0s3 lladdr 08:00:27:38:7e:d0 STALE
192.168.56.254 dev enp0s3 lladdr 08:00:27:b5:90:ee STALE
```

Sur le client SSH :

```
etusio@clissh:~/.ssh$ ip neigh show
192.168.56.12 dev enp0s3 lladdr 08:00:27:32:9e:4e STALE
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:06 REACHABLE
192.168.56.10 dev enp0s3 lladdr 08:00:27:c2:c5:ca STALE
192.168.56.254 dev enp0s3 lladdr 08:00:27:b5:90:ee STALE
```

Q10. Noter les associations adresse IP / adresse MAC présentes sur les deux machines. Sont-elles cohérentes ?

Oui elles sont cohérentes

Q11.Pourquoi l’activation du routage sur la machine de l’attaquant est indispensable au bon fonctionnement de l’attaque MITM ?

Car cette activation permet de router les paquets et donc de se faire passer pour le routeur et récupérer en temps réel les informations.

Q12.Pourquoi cette redirection de ports est indispensable au succès de l'attaque de l'homme du milieu ?

Car cette redirection permet au client de lancer une connexion sur le port 22 et elle s'envoie sur la machine attaquante et pour éviter qu'elle se connecte en SSH à la kali il est redirige les paquets vers 2222 pour que ce soit écouter sans activer le service SSH de la kali. Grâce à l'activation du routage, la kali envoie les bons paquets vers le serveur sans que le client s'en rende compte.

Mise en place d'une attaque ARP Spoofing afin d'obliger le client et le serveur SSH à faire transiter les trames Ethernet échangées par l'attaquant.

Q13.Indiquer en quoi une attaque de type ARP Spoofing peut être utile ici au pirate ?

Elle est utile car elle permet à l'attaquant de prendre les adresses MAC nécessaires pour éviter de se faire remarquer et donc avoir accès aux informations qui transitent entre les 2 machines.

Q14.Comparer les caches ARP du client et du serveur avec les associations notées précédemment lors de la question 10. Qu'en concluez-vous ?

Sur le serveur SSH :

```
etusio@srvssh:~$ ip neigh show
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:06 DELAY
192.168.56.12 dev enp0s3 lladdr 08:00:27:32:9e:4e STALE
192.168.56.11 dev enp0s3 lladdr 08:00:27:32:9e:4e REACHABLE
192.168.56.254 dev enp0s3 lladdr 08:00:27:b5:90:ee STALE
```

Sur le client SSH :

```
etusio@clissh:~/.ssh$ ip neigh show
192.168.56.12 dev enp0s3 lladdr 08:00:27:32:9e:4e STALE
192.168.56.1 dev enp0s3 lladdr 0a:00:27:00:00:06 DELAY
192.168.56.10 dev enp0s3 lladdr 08:00:27:32:9e:4e REACHABLE
192.168.56.254 dev enp0s3 lladdr 08:00:27:b5:90:ee STALE
```

On peut voir que l'adresse MAC des machines "192.168.56.11" et "192.168.56.12" sont les mêmes et donc que le ARP spoofing a bien été réussi.

Q15.À partir de ces différentes observations, expliquez en détails comment fonctionne une attaque ARP Spoofing.

L'attaquant envoie plein de trame pour brouiller le trafic et se faire passer pour la machine cliente et la machine serveur en même temps car il ne vérifie pas les trames ARP envoyé

Q16.Envoyer une requête ping (icmp-écho) depuis le client vers le serveur (192.168.56.10). Puis vérifier à l'aide d'une capture de trame sur la machine Kali Linux que ces dernières passent effectivement bien par l'attaquant. Quels éléments démontrent que l'attaque se déroule correctement ?

```
Ethernet II, Src: PcsCompu_32:9e:4e (08:00:27:32:9e:4e), Dst: PcsCompu_c2:c5:ca (08:00:27:c2:c5:ca)
  Destination: PcsCompu_c2:c5:ca (08:00:27:c2:c5:ca)
  Source: PcsCompu_32:9e:4e (08:00:27:32:9e:4e)
```

```
Ethernet II, Src: PcsCompu_c2:c5:ca (08:00:27:c2:c5:ca), Dst: PcsCompu_32:9e:4e (08:00:27:32:9e:4e)
  Destination: PcsCompu_32:9e:4e (08:00:27:32:9e:4e)
  Source: PcsCompu_c2:c5:ca (08:00:27:c2:c5:ca)
```

Sur les deux screens on peut voir que la source et la destination (de 2 paquets différents) sont les mêmes et est l'adresse MAC de la machine KALI, ces éléments démontrent que l'attaque se déroule correctement

Mise en œuvre et exploitation de l'attaque Man-in-the-Middle

Q17.Recopier la ligne qui contient le login et le mot de passe capturés dans le fichier /var/log/auth.log.

```
Dec  1 09:37:52 kali sshd_mitm[2020]: INTERCEPTED PASSWORD: hostname: [192.168.56.10]; username: [etusio]; password: [Fghijkl1234*] [preauth]
```

Q18.Que contient le fichier /home/ssh-mitm/shell_session_0.txt présent sur Kali Linux ?

```
  GNU nano 4.9.1
Time: 2025-12-01 08:37:52 GMT
Server: 192.168.56.10:22
Client: 192.168.56.11:59988
Username: etusio
Password: Fghijkl1234*
-------------------------
Linux srvssh 4.19.0-8-amd64 #1 SMP Debian 4.19.98-1+deb10u1 (2020-04-27) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Dec  1 09:33:46 2025 from 192.168.56.11
^[]0;etusio@srvssh: ~^Getusio@srvssh:~$ sudo cat /etc/shadowsudo cat /etc/shadow
[sudo] Mot de passe de etusio : Fghijkl1234*
```

Q19.Expliquer pourquoi ce message d'erreur apparaît ?

Car il a appris un nom et une adresse IP avec une adresse MAC (celle de l'attaquante) et quand le client veut se connecter il le bloque car l'adresse MAC ne correspond pas au nom et adresse IP appris

Q20.Proposer une solution afin de pouvoir à nouveau se connecter au service SSH depuis le client.

Il suffit de vider le fichier known_hosts avec la commande

echo > ~/.ssh/known_hosts